

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	• The sales manager gave the team access to the entire internal folder, even though they only needed access to specific promotional materials. • The manager did not revoke the team's access after the meeting. • Sensitive information, including unannounced product information and customer analytics, was stored in the same folder as promotional materials. • The sales representative mistakenly shared the internal folder link instead of the intended promotional materials. • The business partner then publicly posted the link on social media, exposing the internal information. • There were insufficient access restrictions to prevent unauthorized users from viewing the internal documents.

Review	AC-6 addresses the principle of Least Privilege. It states that users, processes, and accounts should receive only the minimum access and authorization necessary to perform their required tasks.
Recommendation(s)	• Give employees access to only the specific files they need, rather than entire folders. • Separate internal confidential documents from materials intended for external sharing. • Use role-based access controls so employees can only access information appropriate for their jobs. • Set automatic expiration dates on temporary folder access. • Require approval before sensitive or unreleased materials can be shared externally. • Regularly review and remove unnecessary permissions. • Maintain access logs to identify who accessed or shared sensitive information.
Justification	These improvements would reduce the chance of accidental or unauthorized disclosure by ensuring that employees have access only to the information necessary for their work. Separating confidential files from promotional materials would make it harder to accidentally share sensitive information. Automatic expiration of temporary access would also prevent employees from retaining access after a meeting or project ends. Finally, role-based access, approval procedures, access logging, and regular audits would provide additional safeguards against accidental sharing and help the company identify and correct inappropriate access.

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.